

TryHackMe - Log Operations

Log Configuration

Log configuration is a multifaceted operation that addresses security, operational stability, regulatory compliance, and debugging needs. Adequately configured logs are crucial in cyber security, operational efficiency, regulatory compliance, and software development, providing organisations with comprehensive system, asset, and resource management statistics. Let's look at and understand the scopes and differences of common purposes of log configuration.

Security Purposes

Logging and configuration for security purposes are typically planned to detect and respond to anomalies and security issues. For example, configuration to verify the authenticity of user activity to ensure authorisation control and timely detection of unauthorised access. The main focus areas of this approach are:

- Anomaly and threat detection
- Logging user authentication data
- Ensuring the system's integrity and data confidentiality

Operational Purposes

Logging and configuring for operational purposes is usually planned to detect and respond to system errors and identify action points to enhance the system's performance, continuity, and reliability. The main focus areas of this approach are:

- Proactively creating reports and notifications for on-system and component status
- Troubleshooting
- Capacity planning
- Service billing

Legal Purposes

Logging and configuring for legal purposes is similar to security purposes; it is usually planned to stay compliant and increase the alignment with regulations and obligations. Here, the laws, regulations, and compliance standards will vary depending on the work's scope, the data being

processed, and the service area being provided. Therefore, each enrollment will come with a set of responsibilities and guidelines to follow. The main focus areas of this approach are:

- Alignment with standards, compliance, regulations, and laws
 - E.g. ISO 27001, COBIT, GDPR, PCI DSS, HIPAA, FISMA

Legal Compliance Example: A company must have an active central log management system, adequate log configuration, 12-month log retention for logs and affiliated system logs (last three months data must always be ready to search), system and component security checks, and overall yearly audit checks to meet PCI logging compliance.

Debug Purposes

Logging and configuring for debug purposes is usually planned to boost the system's reliability and enhance provided features by discovering the bugs and potential fault conditions. This configuration scope is not always implemented in the production environment and is mostly used for testing and developing purposes. The main focus areas of this approach are:

- Increasing visibility for the application debugging
- Enhancing efficiency
- Speeding up the development process

Where To Start After Deciding the Logging Purpose

Key Questions To Ask In Planning Meeting/Session

- What will you log, and for what (asset scope and logging purpose)?
 - Is additional commitment or effort required to achieve the purpose (requirements related to the purpose)?
- How much are you going to log (detail scope)?
- How much do you need to log?
- How are you going to log (collection)?
- How are you going to store collected logs?
 - Is there a standard, process, legislation, or law that you must comply with due to the data you log?
- How are you going to protect the logs?
- How are you going to analyse collected logs?
- Do you have enough resources and workforce to do logging?
- Do you have enough budget to plan, implement and maintain logging?

Configuration Dilemma: Planning and Implementation

Each log configuration plan results from a unique analysis of the scope, assets, objectives, requirements, and expectations to be applied. Expectations, requirements, and limits are determined with the involvement of system administrators, legal and financial advisors, and managers, if possible. In summary, the main source of the dilemma is finding the balance between requirements, scope, details, and price (financial and labour costs, risks, and investment). During the meeting, there might be some points where participants get off the point, but it is vital to keep in mind that the main objective of the meeting is:

- Meeting specific operational and security requirements (non-negotiable) while also considering the feasibility of improving the capability by implementing additional data and insights.

Last but not least, a comprehensive risk assessment, prioritizing security, compliance, and legal needs will be helpful to navigate this dilemma. Finding the balance in "operational and management" level decisions and achieve secure, efficient, proactive, resilient, and sustainable outcomes in the ever-evolving threat/IT landscape and technical operations.

Translating "Requirements" and "Aspirations" To Operational Level

Let's take a closer look at exactly how the dilemma arose:

Base Requirements	Aspirations for Better Insights
• What happened? • When did it happen? • With time data (if possible). • Where did it happen? • Network, system, folder, path, interface. • Who/What caused it to occur? • From which log source?	• Is it possible to have more data? • More details. • How sure can I be that this is true? • What is affected? • What will happen next? • Is there anything else that requires attention? • What should I do about the incident?

While the main focus is the same, two question sets represent two distinct dimensions of logging and analysis:

- The base part heavily relies on an incident detection mindset. Still, it provides a solid framework for logging and analysis but is reactive. The requirements are a good place to start, but it is primarily helpful against known threats.
- The aspirations part is more focused on a threat-hunting mindset. Therefore, it is proactive and requires more resources due to the need to go above and beyond. Therefore, this part is more helpful against advanced and sophisticated threats.

The baseline part is necessary for a solid incident detection and response scope foundation. However, adopting proactive aspirations by adding them to the operational vision is strongly

recommended, given the ever-evolving threat landscape.

Principles and Difficulties

Logging Principles

Logging is a critical aspect of the cyber-security and IT operations. It is a process that is as burdensome as functional and requires active resource utilization. Therefore, it is crucial to implement a proper logging operation and ensure its effectiveness and efficiency. There are multiple principles which help achieve the mentioned goal. The table below highlights some of the essentials.

Collection	- Define the logging purpose. - Collect what you will need and use. - Do not collect irrelevant data. - Avoid log noise.
Format	- Log at the correct level and detail. - Implement a consistent log format. - Ensure that timestamps in logs are accurate and synchronised.
Archiving and Accessibility	- Define log retention policies and implement them. - Store log data and make sure the important part is available for analysis. - Create backups of stored log data and used systems.
Monitoring and Alerting	- Create alerts and notifications for important and noteworthy cases. - Focus on actionable alerts and avoid noise.
Security	- Protect logs by implementing access controls. - Implement encryption if required. - Use a dedicated log management solution.
Continuous Change	- Logging sources, types, and messages are constantly changing and being updated. - Be open to continuous change. - Train your personnel.

Challenges

Challenges are as much a part of log management as principles. However, most of them can be addressed in the planning section. The table below highlights the main challenges of logging.

Data Volume and Noise	- Having multiple data sources to deal with. - Differences in the log volumes created by applications. - Some applications generate an insufficient amount of logs. - Large-scale applicants could generate massive log volumes. - Some logs can provide non-essential data and make the identifying process difficult.
System Performance and Collection	- Log collection can slow down the system's performance. - Systems are not always "state of the art". - Some "sensitive" or "ancient" systems are impossible to touch. - Deployment and optimisation challenges. - Managing system and agent version updates and synchronisation in large-scale networks is overwhelming.
Process and Archive	- Having multiple data formats to deal with it. - Parsing different data sources and formats is time-consuming and error-prone. - Balancing the log retention can be challenging. - Especially when dealing with many compliance regulations and standards.
Security	- Ensuring data security is a task/challenge in itself.
Analysis	- Combining, correlating, and analysing data from multiple sources to understand the context of an incident is a time-consuming process that requires significant computing resources and expertise. - Achieving this in real-time is also another challenge in the same scope. - Avoiding false positives/negatives is overwhelming.
Misc	- Lack of planning and roadmap. - Lack of financial resources/budget. - Lack of implementation scenarios, playbooks, and exercises. - Lack of technical skills to implement, maintain, and analyse. - Focusing on log collection instead of the analysis phase. - Ignoring human factors and potential system errors